

IT Security Basics

Jobs in IT Security

Agenda

- Overview of jobs (examples)
  - Security Operation Center Analyst
  - Vulnerability Analyst
  - Penetration Tester
  - Incident Responder
  - Digital Forensics Analyst
  - Governance, Risk, and Compliance (GRC) Specialist
  - Security Architect
  - CISO (Chief Information Security Officer)

Agenda

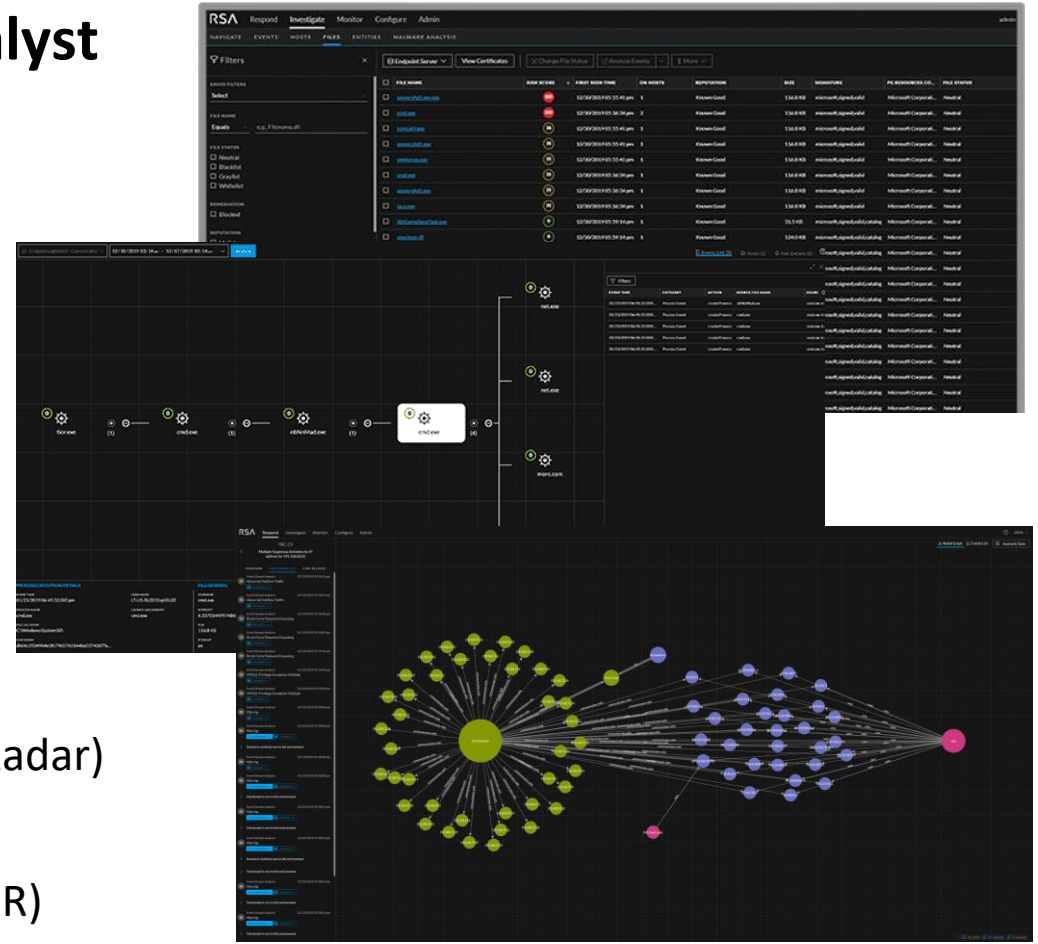
- Overview of certificates (examples)
  - CompTIA Security+
  - CEH
  - CISSP
  - OSCP
  - CISM
  - GESC
  - CHFI
  - CCSP
- Self study – taking a closer look on jobs/certificates you are interested in

Overview of jobs

FH University of Applied Sciences TECHNIKUM WIEN

Security Operation Center Analyst

- Level: Entry
- Tasks:
  - Monitoring of security events in real time
  - Analysis of log data & alarms from SIEM systems
  - Detection and escalation of security incidents
- Tools:
  - SIEM-Systeme (Splunk, ArcSight, QRadar)
  - IDS/IPS (Snort, Suricata)
  - Endpoint Detection & Response (EDR)



Sources: https://www.netwitness.com/products/cloud-siem/
https://www.netwitness.com/products/endpoint-security-endpoint-detection-response/

Security Operation Center Analyst

- Skills:
  - Log analysis and pattern recognition
  - Basics of incident handling
  - Knowledge of network security
- Courses in specialization:
  - Network Security
  - Vulnerability Analysis

Technical skills:



Management skills:



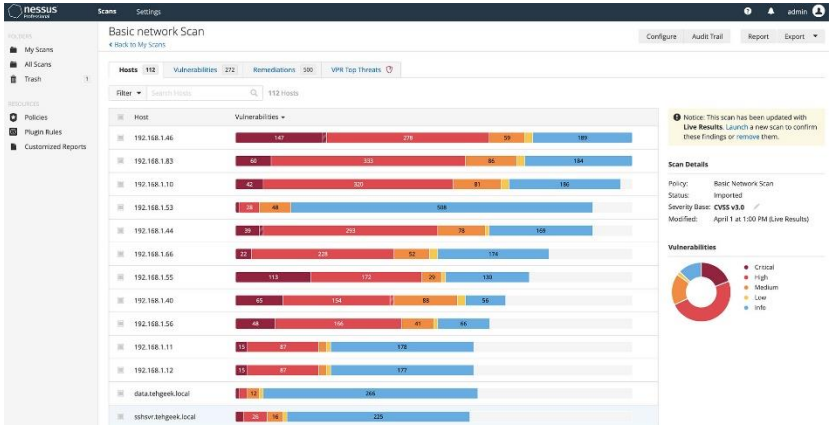
Practical / Hands-on:

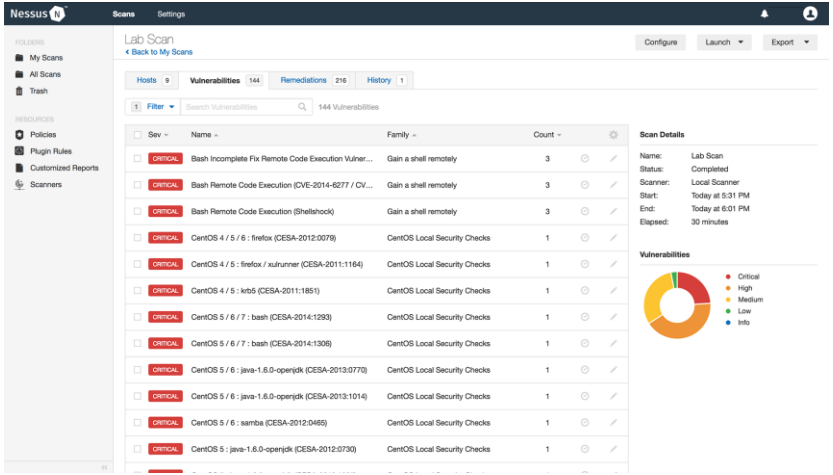


Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Vulnerability Analyst

- Level: Entry
- Tasks:
  - Identification and assessment of security vulnerabilities in the companies systems, products or tools
  - Use of vulnerability scanners for risk analysis
  - Collaboration with developers to eliminate vulnerabilities
- Tools:
  - Vulnerability scanners (Nessus, OpenVAS, Qualys)
  - CVE or CWE databases and collections of exploits (Exploit-DB)





Sources: https://www.tenable.com/products/nessus/nessus-professional

Vulnerability Analyst

- Skills:
  - Understanding OWASP Top 10 and CVSS assessments
  - Network analysis and penetration testing basics
  - Patch management
- Courses in specialization:
  - Web Security
  - Vulnerability Analysis
  - DevOps and Security

Technical skills:



Management skills:



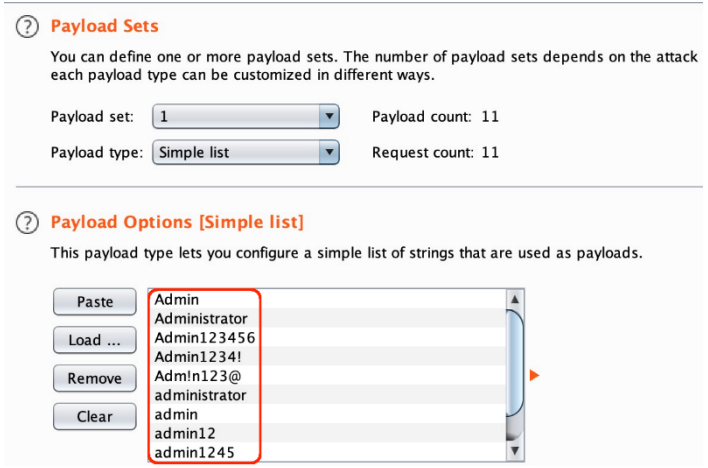
Practical / Hands-on:

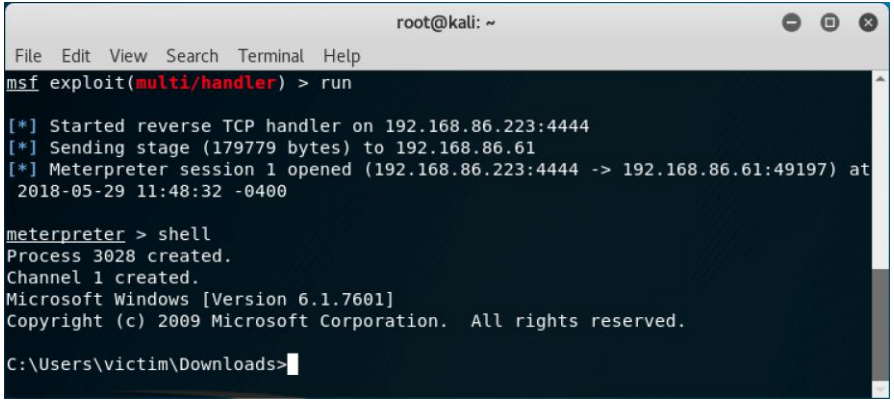


Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Penetration Tester (Ethical Hacker)

- Level: Mid-Level
- Tasks:
  - Simulation of attacks on systems and networks
  - Manual and automated penetration testing
  - Creation of vulnerability reports and recommendations for action
- Tools:
  - Kali Linux, Metasploit, Burp Suite
  - Wireshark, Nmap, Hydra
  - Manual exploitation techniques





Sources: https://www.optiv.com/sites/default/files/inline-images/bruteforce%2010.png
https://www.offsec.com/wp-content/uploads/2018/05/msfu-intro.png

Penetration Tester (Ethical Hacker)

- Skills:
  - Exploit development and scripting (Python, Bash)
  - Knowledge of web security (XSS, SQLi, CSRF)
  - Social Engineering and OSINT
- Courses in specialization:
  - Web Security
  - Exploit Development
  - Vulnerability Analysis
  - Mobile Security
  - DevOps and Security

Technical skills:



Management skills:



Practical / Hands-on:



Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Incident Responder

- Level: Mid-Level
- Tasks:
  - Reacting to/Intervening in cyber attacks and security incidents
  - Triage in case of an incident
  - Documentation of incidents
  - Coordination of forensics and mitigation
  - Development and tests of incident response playbooks
- Tools
  - SIEM, EDR, IDS/IPS
  - Memory and disk forensics tools like Volatility, Autopsy



Source: https://jamcyber.com/blog/cyber-security-resources/incident-response-plan/

Incident Responder

- Skills
  - Response strategies to attacks like ransomware and APTs
  - Live forensics and malware analysis
  - Fast decision making in crisis situations (Keeping calm)
- Courses in specialization:
  - Web Security
  - Vunlerability Analysis
  - Exploit Development
  - DevOps and Security

Technical skills:



Management skills:



Practical / Hands-on:

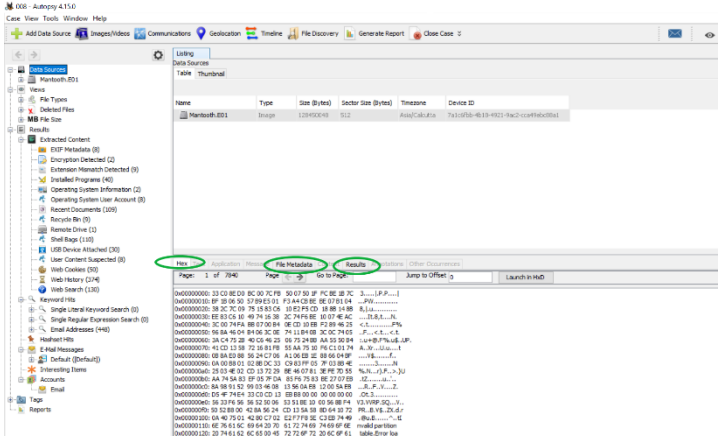


Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Digital Forensics Analyst



- Level: Mid-Level
- Tasks:
  - Collection and analysis of digital evidence after attacks or cybercrime
  - Recovery and analysis of deleted digital evidence (if possible)
  - Investigation of hard disks, networks and storage media
  - Report preparation for court proceedings
  - Testify as an expert in court
- Tools
  - Forensic tools such as Autopsy, FTK, EnCase
  - Analysis tools such as Volatility, Wireshark
  - Reverse Engineering tools such as IDA Pro, Ghidra



Sources: https://media.geeksforgeeks.org/wp-content/uploads/20200830101923/datasrc.png
https://www.computersciencedegreehub.com/wp-content/uploads/2021/11/digital-forensics.jpg

Digital Forensics Analyst

- Skills:
  - Knowledge of Windows and Linux forensics
  - Data recovery and timeline analysis
  - Evidence preservation and chain of custody

Technical skills:



Management skills:



Practical / Hands-on:



Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Governance, Risk, and Compliance (GRC) Specialist

- Level: Mid-Level
- Tasks:
  - Implementation of security guidelines and standards (e.g. ISO 27001, NIST, GDPR or HIPPA)
  - Risk assessment and compliance controls
  - Continuous review of IT compliance
  - Security audits and training
- Tools:
  - GRC-platforms such as RSA Archer or ServiceNow
  - Risk-Assessment-Frameworks



Sources: https://www.infosectrain.com/blog/risk-management-lifecycle/
https://jethrojeff.com/

Governance, Risk, and Compliance (GRC) Specialist

- Skills:
  - Knowledge of IT laws and data protection
  - Auditing and documentation
  - Communication skills for management and IT teams

Technical skills:



Management skills:



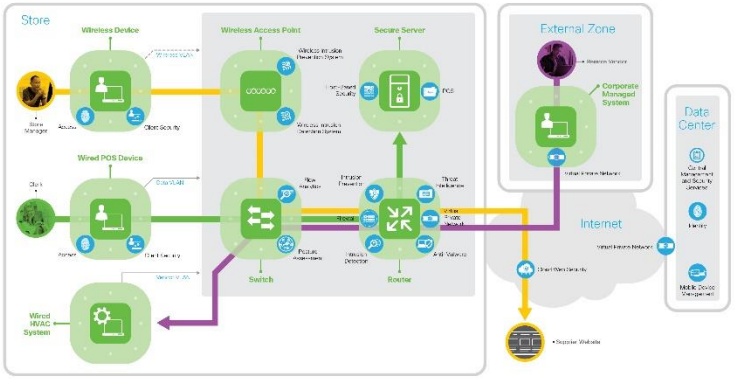
Practical / Hands-on:

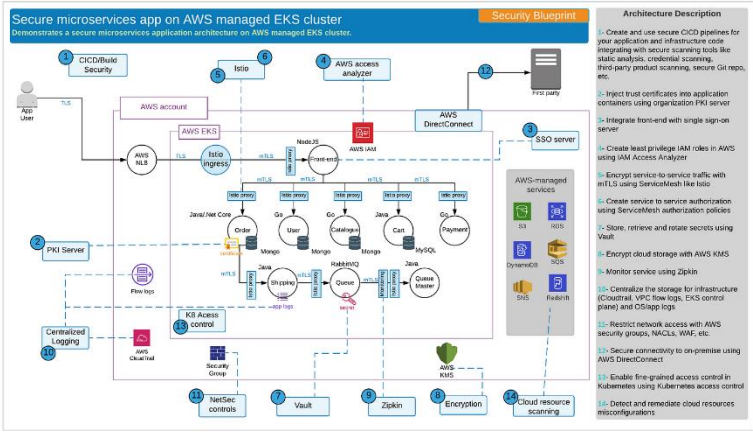


Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Security Architect

- Level: Senior
- Tasks:
  - Design and implementation of security architectures and concepts
  - Optimization of existing security solutions in the network and systems
  - Development of secure networks and cloud security solutions
  - Evaluation of new security solutions
- Tools:
  - For Cloud Security: AWS or Azure Security
  - For Network Security: Firewalls, Zero Trust Concept, etc.





Security Architect

- Skills:
  - Threat modeling and architecture reviews
  - Security protocols (TLS, IPsec, VPN)
  - Experience with enterprise security solutions
- Courses in specialization:
  - Network Security

Technical skills:



Management skills:



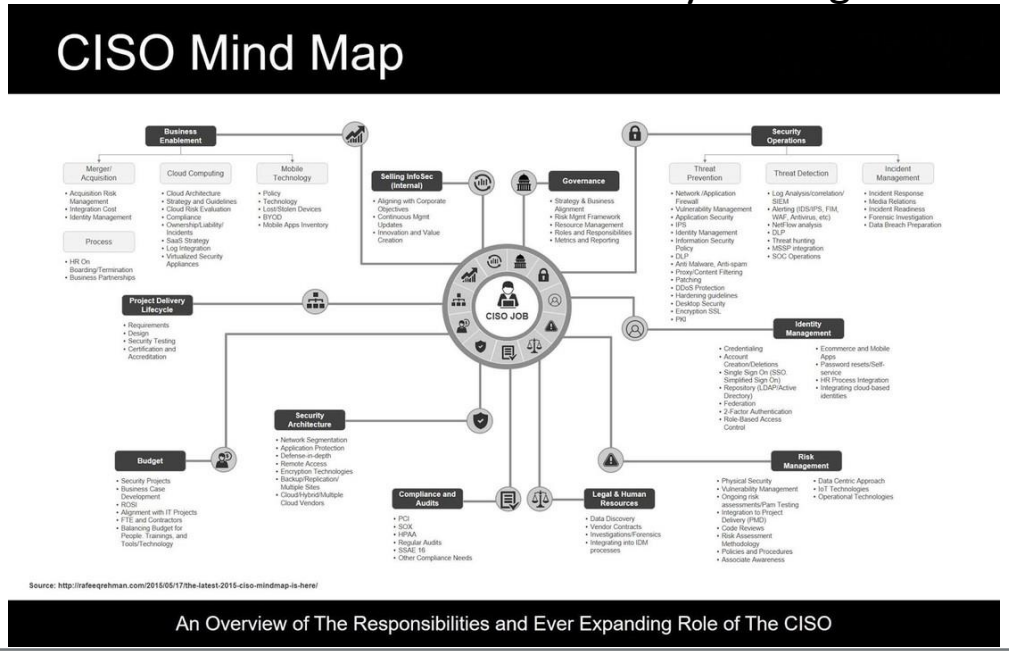
Practical / Hands-on:



Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

CISO (Chief Information Security Officer)

- Level: Senior
- Tasks:
  - Leadership of development and implementations of information security strategies
  - Strategic management of IT security in the company
  - Risk management and budget planning for security projects
  - Communication with the management board and authorities
- Tools:
  - GRC-platforms
  - Cybersecurity dashboards



Source: https://www.linkedin.com/pulse/ciso-toolkit-100-tools-needs-job-araveinth-gopinath-2w0ac

CISO (Chief Information Security Officer)

- Skills:
  - Comprehensive knowledge of security technologies, standards, laws and processes
  - Leadership skills and communication
  - Understanding of business and security
  - Experience in IT strategy and compliance

Technical skills:



Management skills:



Practical / Hands-on:



Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

Overview of certificates

FH University of Applied Sciences TECHNIKUM WIEN

CompTIA Security+

- Target group: Beginner
- Costs: ~400€ + costs of the course (depending on the course)
- Topics:
  - Basics of network security
  - Basics of threats
  - Basics of cryptography
  - Basics of risk and compliance
  - Basics of security operations

Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://www.comptia.org/de/zertifizierungen/security

CEH (Certified Ethical Hacker)

- Target group: Pentester
- Costs: ~1200€ + costs of the course (depending on the course 4000-13500€)
- Topics:
  - Hacking methods
  - Exploits
  - Attack techniques
  - Tools like Metasploit
  - How to defend against common attacks like
    - Trojan, worm, virus
    - SQL Injection
    - Direct-Denial-of-Service (DDoS)

Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://www.technow.com/tn-555-ceh-certified-ethical-hacker-v13/

CISSP (Certified Information Systems Security Professional)

- Target group: Security managers, architects or CISOs
- Costs: ~750€ + costs of the course (4000€ - 6000€ depending on the course)
- Topics:
  - Security and Risk Management
  - Asset security
  - Security Architecture and Engineering
  - Communication and Network Security
  - Identity and Access Management (IAM)
  - Security Assessment and Testing
  - Security Operations
  - Software Development Security

Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg

https://www.isc2.org/certifications/cissp

OSCP (OffSec Certified Professional)

- Target group: Advanced pentester
- Costs: ~1750€ + costs for lab access, additional courses possible but not necessary
- Topics:
  - Hands-on hacking
  - Exploit development
  - Privilege escalation
  - SQL Injections
  - Client side attacks
  - Information gathering + Vulnerability scanning
  - Report writing for pentester





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://www.isc2.org/certifications/cissp

CISM (Certified Information Security Manager)

- Target group: IT Security manager
- Costs: ~750€ + costs for the course (900€ – 1200€ depending on the course)
- Topics:
  - Track, investigate, respond to and recover from information security issues
  - Information Systems Audit process
  - IT Governance and Management
  - Information Systems Acquisition, Development and Implementation.
  - Information Systems Operations, Maintenance and Support
  - Protection of Information Assets

Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://esi.edu.sa/wp-content/uploads/2022/12/CISM-Certified-Information-Security-Manager-1536x1024.png

GSEC (GIAC Security Essentials)

- Target group: Security generalists
- Costs: ~1000€ + costs for the course (7300-8500€ depending on the course)
- Topics:
  - Knowledge of network security
  - Knowledge of cyber defense
  - Knowledge of incident handling
  - Knowledge of security measurements
  - Knowledge of Linux and Windows and OS Hardening
  - Knowledge pf pentesting and vulnerability scanning
  - Knowledge WLAN Security

Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://images.credly.com/images/8e6bde54-8a33-4ec0-9d70-90fcde581bcf/image.png

CHFI (Computer Hacking Forensic Investigator)

- Target group: Forensic scientist, incident responder
- Costs: ~650€ + costs for the course (3500€ – 5300€ depending on the course)
- Topics:
  - Windows, Linux and Mac forensic
  - Network forensic
  - Malware analysis
  - Cloud forensic
  - Mobile forensic
  - E-Mail and social engineering forensic

Level of difficulty



C|HFI™
Computer Hacking Forensic INVESTIGATOR

Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://www.afralti.org/ec-council/computer-hacking-forensic-investigator-chfi/

CCSP (Certified Cloud Security Professional)

- Target group: cloud security specialist
- Costs: ~700€ + costs for the course (3200€ – 4200€ depending on the course)
- Topics:
  - Cloud Concepts, Architecture and Design
  - Cloud Data Security
  - Cloud Platform & Infrastructure Security
  - Cloud Application Security
  - Cloud Security Operations
  - Legal, Risk and Compliance

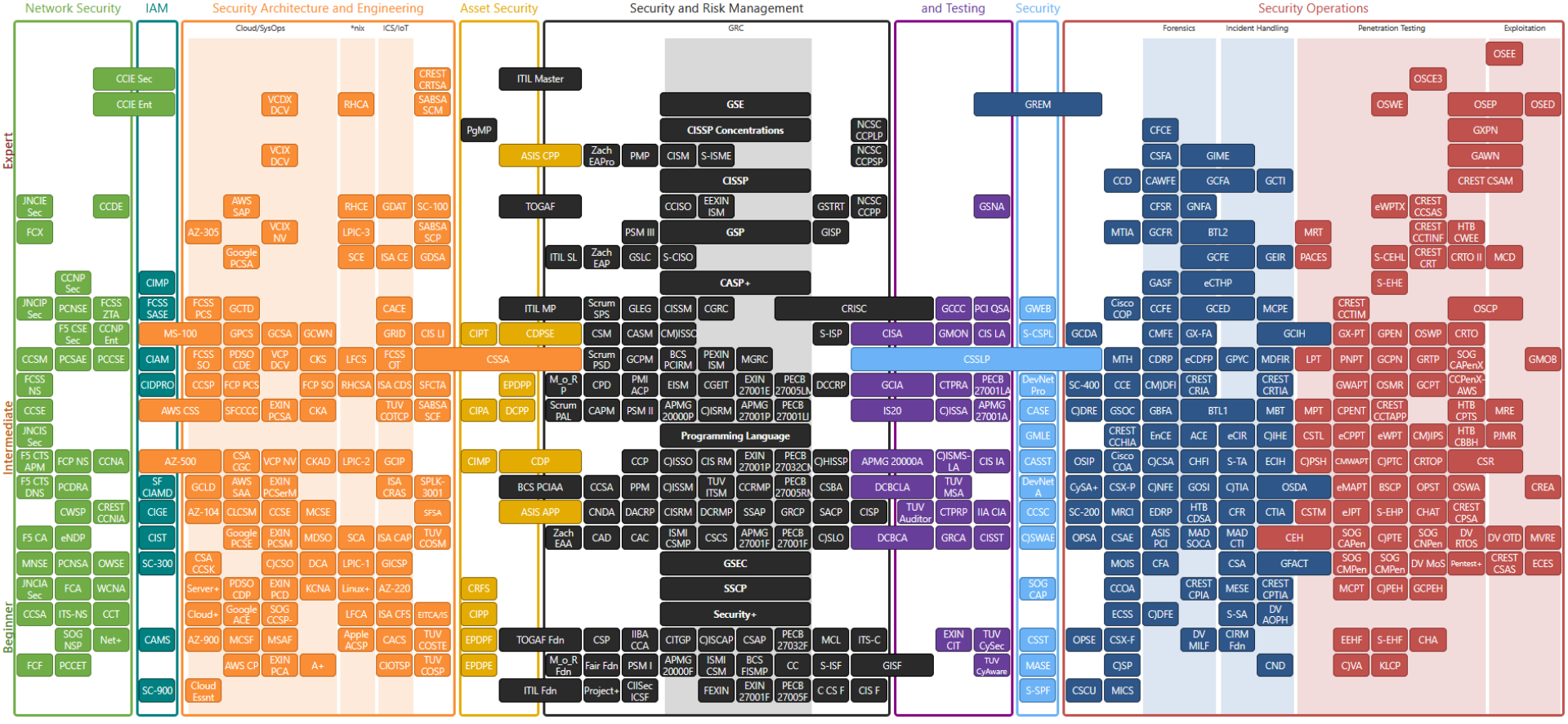
Level of difficulty





Source: https://thumbs.dreamstime.com/z/isolated-five-four-three-two-one-star-rating-icons-set-isolated-five-four-three-two-one-star-rating-icons-134801563.jpg
https://www.isc2.org/certifications/ccsp

Security Certification Roadmap (State: July 2024)



Source: https://pauljerimy.com/security-certification-roadmap/